

Offensive Security — Exercises

Penetration Testing, Red Teaming, Kali Linux & Metasploit

Cyber Security Master Lecture

June 7, 2026

Authorization & ethics. Perform the hands-on tasks *only* inside the isolated lab described below, or on platforms that explicitly permit it (TryHackMe, Hack The Box, your own VMs). Scanning, exploiting, or even probing systems you do not own — without written permission — is a criminal offence (e.g. §202a–c StGB in Germany). By doing these exercises you confirm you act only against your own lab.

Lab setup (do this first)

Goal: a fully isolated network with one attacker and one target.

1. Install VirtualBox or VMware (free).
2. Import the **Kali Linux** VM image (<https://www.kali.org/get-kali/>).
3. Import **Metasploitable 2** (<https://sourceforge.net/projects/metasploitable/>).
4. Set *both* VMs' network adapter to **Host-Only** (or an Internal Network). **No bridged/NAT adapter on Metasploitable.**
5. Boot both, log in to Metasploitable (`msfadmin/msfadmin`), run `ip a` to note its IP. From Kali, `ping` it to confirm connectivity *and* that it has no internet route.

Throughout, `TARGET` = the Metasploitable IP, `LHOST` = your Kali IP.

1. Concepts & Ethics (no computer needed)

Exercise 1.1 (*terminology*)

Define and contrast *vulnerability scan*, *penetration test*, and *red team engagement*. For each, state the primary goal and a typical deliverable. [6 pts]

Exercise 1.2 (*boxes*)

A client gives your team a low-privilege VPN account and an internal network diagram, but no source code. Which testing model is this (black/grey/white box)? Name one advantage and one limitation versus a pure black-box test. [4 pts]

Exercise 1.3 (*legal*)

You are asked to “just have a quick look” at a partner company’s public website for vulnerabilities — no contract yet, “it’s fine, we know them”. List three documents/conditions that must exist before you run a single `nmap` command, and explain the legal risk of proceeding without them. [6 pts]

Exercise 1.4 (*killchain*)

Map the following actions to the correct phase of the attack lifecycle (Recon, Scanning/Enum, Exploitation, Post-Exploitation, Lateral Movement, Reporting): (a) dumping local password hashes, (b) querying certificate-transparency logs for subdomains, (c) using stolen hashes to authenticate to a second server, (d) writing CVSS scores for each finding. [4 pts]

2. Reconnaissance & Enumeration (lab)

Exercise 2.1 (*nmap-basics*)

From Kali, run a service/version scan of all ports on the target and save the output:

```
nmap -sV -p- -oA recon_target <TARGET>
```

List five open services with their version strings. Which *one* immediately looks suspicious/backdoored, and why? [6 pts]

Exercise 2.2 (*nmap-scripts*)

Re-run `nmap` with the default script set (`-sC`) against the same host. Pick two scripts that fired and explain in one sentence each what information they revealed. [4 pts]

Exercise 2.3 (*passive*)

Without touching the target, explain how you would discover an organisation's externally-facing assets using only *passive* techniques. Name three distinct sources (e.g. DNS, certificate transparency, Shodan) and what each yields. [6 pts]

3. Exploitation with Metasploit (lab)

Exercise 3.1 (*msf-workflow*)

Start `msfconsole`. Using the vsftpd finding from Exercise 2.1, search for and select the matching exploit module, set the required option(s), and run it. Paste the commands you used and the output proving you obtained a shell. What privilege level did you land with (`whoami`)? [8 pts]

Exercise 3.2 (*module-types*)

For the module you just used, identify whether it is an **exploit**, **auxiliary**, or **post** module. Then list one example of each of the other two module types available in Metasploit and what they are used for. [6 pts]

Exercise 3.3 (*payload-choice*)

Explain the difference between a *bind* and a *reverse* payload. In a typical engagement where the target sits behind a firewall that blocks inbound connections but allows outbound, which one do you choose and why? [4 pts]

Exercise 3.4 (*msfvenom*)

Using `msfvenom`, generate a standalone Linux reverse-shell payload (you do *not* need to deliver it) pointing back to your Kali host on port 4444. Provide the full command. Then describe how you would set up the matching **multi/handler** listener in `msfconsole` to catch the connection. [6 pts]

4. Post-Exploitation & Red Team Thinking

Exercise 4.1 (*postex*)

You have a shell on the target. List, in order, the first four things you would attempt and the goal of each (e.g. situational awareness, privilege escalation, credential harvesting, persistence). [6 pts]

Exercise 4.2 (*pivot*)

Briefly explain what *pivoting* / lateral movement means and why a single compromised host loops you back to the “scanning & enumeration” phase. Give one Metasploit/Meterpreter feature that enables pivoting. [4 pts]

Exercise 4.3 (*redvsblue*)

A red team gains domain admin but is detected by the SOC after two days. Was the engagement a success or a failure? Argue both sides, then state what the *primary* deliverable of a red team engagement is (versus a pentest). [6 pts]

Exercise 4.4 (*defence*)

For *three* techniques you used or read about today (e.g. the vsftpd backdoor exploit, hash dumping, reverse shells), name a concrete defensive control that would prevent or detect it. [6 pts]

Challenge (optional, bonus)**Exercise 4.5** (*capstone*)

Treat the lab as a mini-engagement. Produce a one-page “finding” for the most critical vulnerability you exploited, in proper report format: title, severity (assign a CVSS vector), affected asset, description, reproduction steps, evidence, and remediation. [10 bonus pts]